

# NOC TRANSFORMATION

# PHASE 3

## SOC & CLOUD

SIEM · Logs · AWS / Azure / GCP · Sécurité · Corrélation · Automatisation avancée

|              |                                                                                         |
|--------------|-----------------------------------------------------------------------------------------|
| Destinataire | Direction Générale                                                                      |
| Phase        | Phase 3 / 4                                                                             |
| Périmètre    | SIEM · Logs · AWS / Azure / GCP ·<br>Sécurité · Corrélation ·<br>Automatisation avancée |
| Date         | Mai 2025                                                                                |
| CONFIDENTIEL | Usage Interne — Direction                                                               |

### CONTENU DE CE DOCUMENT

- Architecture SOC — intégration dans le NOC
- SIEM : déploiement, sources de logs, règles de détection
- Supervision AWS, Azure, GCP — métriques et alertes cloud
- Supervision sécurité : IDS/IPS, comportements anormaux, incidents
- Corrélation multi-sources : réseau + sécurité + cloud
- Cas d'usage de détection avancée
- Runbooks incidents sécurité (N1/N2)
- Automatisations prioritaires Phase 3
- Dashboards SOC et Cloud
- KPI sécurité et cloud
- Plan de déploiement Phase 3

# 1. INTÉGRATION SOC DANS LE NOC

La Phase 3 franchit une étape majeure : le NOC devient un centre de supervision unifié NOC+SOC. La frontière entre réseau et sécurité disparaît — un incident réseau peut être une attaque, une anomalie sécurité peut saturer le réseau.

## POURQUOI UNIFIER NOC ET SOC

En télécoms B2B, les incidents sécurité et réseau sont de plus en plus liés :

- Une saturation de bande passante peut être un DDoS en cours
- Un équipement injoignable peut être compromis
- Une anomalie de flux peut indiquer une exfiltration de données
- Un lien VPN instable peut signaler une tentative d'intrusion

La corrélation entre événements réseau (Phase 1-2) et événements sécurité (Phase 3) multiplie la capacité de détection.

Objectif : un seul écran de vérité pour l'analyste NOC/SOC.

| Domaine             | Ce que ça apporte                                                                                                                | Outil recommandé                                  |
|---------------------|----------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------|
| SIEM                | Collecte centralisée des logs, détection de patterns malveillants, corrélation multi-sources, alertes sur comportements anormaux | Wazuh (Open Source) ou Elastic SIEM               |
| IDS/IPS             | Détection d'intrusions réseau en temps réel, signatures d'attaques connues, anomalies de flux                                    | Snort/Suricata (si dédié) ou IPS intégré Firewall |
| Supervision Cloud   | Métriques workloads AWS/Azure/GCP, coûts, disponibilité services cloud, connectivité                                             | CloudWatch + Azure Monitor + GCP Operations       |
| Log Management      | Centralisation logs OS, applications, réseau — recherche forensique, audit compliance                                            | Elasticsearch + Kibana ou Splunk (Enterprise)     |
| Threat Intelligence | Enrichissement IP/domaines malveillants, IOCs, réputation                                                                        | AbuseIPDB / VirusTotal API / MISP                 |
| Corrélation NOC+SOC | Croiser alertes réseau + sécurité pour identifier les vraies menaces vs faux positifs                                            | Wazuh + SolarWinds + ITSM                         |

## 2. SIEM — DÉPLOIEMENT ET CONFIGURATION

### 2.1 Architecture SIEM Recommandée (Wazuh)

Wazuh est recommandé pour son excellente couverture, sa gratuité (open source) et son intégration native avec Elastic Stack. Il supporte Windows, Linux, firewalls, et cloud.

| Composant Wazuh               | Rôle                                                                                               | Déploiement                                      |
|-------------------------------|----------------------------------------------------------------------------------------------------|--------------------------------------------------|
| Wazuh Agents                  | Collecte des logs et événements sur chaque serveur supervisé (Windows Events, Linux syslog, audit) | Installé sur chaque serveur de production client |
| Wazuh Manager                 | Analyse les événements, applique les règles de détection, génère les alertes                       | Serveur dédié NOC — ou VM haute dispo            |
| Wazuh Indexer (Elasticsearch) | Stockage et indexation des logs — recherche forensique rapide                                      | Cluster Elasticsearch 3 nœuds minimum            |
| Wazuh Dashboard (Kibana)      | Interface graphique — dashboards sécurité, visualisation événements                                | Accès NOC + RSSI                                 |
| Filebeat / Logstash           | Collecte logs firewall, switch, réseau via Syslog                                                  | Forwarded depuis équipements réseau              |

### 2.2 Sources de Logs à Intégrer

| Source de logs        | Type d'événements                                             | Priorité collecte             | Cas de détection                                |
|-----------------------|---------------------------------------------------------------|-------------------------------|-------------------------------------------------|
| Windows Event Logs    | Connexions, authentications, erreurs système, audit politique | HAUTE — clients critiques     | Brute force, élévation de privilèges, malware   |
| Linux Syslog / Auditd | Connexions SSH, sudo, modifications fichiers, processus       | HAUTE                         | Accès non autorisé, persistance, exfiltration   |
| Firewall Syslog       | Connexions bloquées, allowed, VPN, NAT, IPS                   | HAUTE — tous firewalls        | Port scanning, accès interdit, tunnels suspects |
| Switches & Routeurs   | Authentications, changements config, erreurs                  | MOYENNE                       | Modifications non autorisées, ARP spoofing      |
| IPBX / VoIP           | Appels entrants/sortants inhabituels, échecs auth SIP         | MOYENNE — Call Centers        | Toll fraud, SIP brute force, vishing            |
| Applications métiers  | Logs applicatifs, erreurs, accès données                      | MOYENNE-HAUTE selon criticité | Injection SQL, accès données sensibles          |
| Cloud (AWS/Azure/GCP) | CloudTrail, Activity Logs, audit IAM                          | HAUTE si cloud produit        | API abuse, accès ressources non autorisé        |
| DNS                   | Requêtes DNS internes et externes                             | MOYENNE                       | DNS tunneling, DGA malware, exfiltration        |

### 2.3 Règles de Détection SIEM Prioritaires

| Règle de détection | Pattern détecté | Sévérité | Priorité NOC | Action |
|--------------------|-----------------|----------|--------------|--------|
|--------------------|-----------------|----------|--------------|--------|

|                                        |                                                     |          |    |                            |
|----------------------------------------|-----------------------------------------------------|----------|----|----------------------------|
| <b>Brute Force SSH/RDP</b>             | 5 échecs auth en 1 min depuis même IP               | HAUTE    | P2 | Bloquer IP + notifier      |
| <b>Connexion hors horaires</b>         | Admin se connecte en dehors des plages autorisées   | HAUTE    | P2 | Alerter RSSI               |
| <b>Escalade de privilèges</b>          | sudo/su vers root sur serveur de production         | HAUTE    | P2 | Alerter RSSI + N2          |
| <b>Port Scanning</b>                   | 1 IP contacte > 50 ports en < 30s                   | HAUTE    | P2 | Bloquer IP firewall        |
| <b>Exfiltration de données</b>         | Transfert sortant > 500 MB vers IP externe inconnue | CRITIQUE | P1 | Isoler machine + alerter   |
| <b>Malware signature</b>               | Processus correspondant à signature malware connue  | CRITIQUE | P1 | Isoler + forensique        |
| <b>Configuration firewall modifiée</b> | Changement de règle firewall non planifié           | HAUTE    | P2 | Alerter RSSI + N2          |
| <b>Compte désactivé utilisé</b>        | Tentative d'utilisation d'un compte désactivé       | HAUTE    | P2 | Alerter admin AD           |
| <b>Toll Fraud VoIP</b>                 | Volume appels internationaux anormal (+300%)        | HAUTE    | P1 | Couper trunk SIP + alerter |
| <b>API Cloud abuse</b>                 | Nb d'appels API cloud > 10x la moyenne horaire      | HAUTE    | P2 | Alerter + investiguer      |

## 3. SUPERVISION CLOUD — AWS / AZURE / GCP

Les clients B2B migrent massivement vers le cloud. Le NOC doit superviser les workloads cloud avec la même rigueur que l'infrastructure on-premise.

### 3.1 Métriques Cloud à Superviser par Fournisseur

| Domaine                 | AWS                                                                | Azure                                                                  | GCP                                                             | Seuil critique                                    |
|-------------------------|--------------------------------------------------------------------|------------------------------------------------------------------------|-----------------------------------------------------------------|---------------------------------------------------|
| <b>Compute</b>          | EC2 CPU/RAM/réseau<br>ASG scaling events<br>Lambda errors/throttle | VM CPU/RAM/disk<br>Scale Set events<br>Azure Functions errors          | GCE CPU/RAM<br>Cloud Run errors<br>GKE node health              | <b>CPU &gt; 90% / Instance DOWN</b>               |
| <b>Stockage</b>         | S3 error rates EBS<br>latency RDS storage                          | Storage Account errors Managed Disk<br>latency Azure DB storage        | GCS error rates<br>Persistent Disk<br>latency Cloud SQL storage | <b>Latence I/O &gt; 30ms / Espace &lt; 10%</b>    |
| <b>Réseau</b>           | VPC Flow Logs<br>anomalies ELB 5xx errors<br>VPN Gateway state     | NSG anomalies<br>Application GW 5xx<br>VPN Gateway                     | VPC Flow anomalies<br>Cloud Armor Cloud VPN                     | <b>5xx &gt; 1% / VPN DOWN</b>                     |
| <b>Bases de données</b> | RDS CPU/connections<br>DynamoDB throttle<br>ElastiCache hit ratio  | Azure SQL performance Cosmos<br>DB RU Cache for Redis                  | Cloud SQL performance<br>Firestore quotas<br>Memorystore        | <b>Connections max &gt; 80%</b>                   |
| <b>Sécurité cloud</b>   | CloudTrail events<br>GuardDuty findings IAM anomalies              | Azure Defender alerts<br>Activity Log anomalies Azure AD sign-in risks | Security Command Center GCloud audit logs Identity anomalies    | <b>Alerte immédiate sur tout finding critique</b> |
| <b>Coûts</b>            | Budget alerts Cost anomaly detection                               | Budget alerts Cost Management anomaly                                  | Budget alerts Billing anomaly                                   | <b>Dépassement budget &gt; 120%</b>               |

### 3.2 Supervision de la Connectivité Cloud

La connectivité entre l'infrastructure client (on-premise) et le cloud est aussi critique que les workloads eux-mêmes.

| Type de connectivité                 | Métriques supervisées                             | Seuils d'alerte                            | Outil                               |
|--------------------------------------|---------------------------------------------------|--------------------------------------------|-------------------------------------|
| <b>AWS Direct Connect</b>            | État du port DX, BW utilisée, erreurs, BGP status | <b>Port DOWN / BW &gt; 80%</b>             | SolarWinds NPM + AWS CloudWatch     |
| <b>Azure ExpressRoute</b>            | Circuit state, BW, BGP peers, latence             | <b>Circuit Down / Peering KO</b>           | SolarWinds NPM + Azure Monitor      |
| <b>VPN Site-to-Site Cloud</b>        | Tunnel state, packets perdus, latence             | <b>Tunnel DOWN / Perte &gt; 1%</b>         | SolarWinds NPM + CloudWatch VPN     |
| <b>Internet (accès cloud public)</b> | Latence vers endpoints cloud, disponibilité       | <b>Latence &gt; 100ms / Dispo &lt; 99%</b> | ThousandEyes ou agents synthétiques |
| <b>Peering multi-cloud</b>           | Latence cross-cloud, BW, disponibilité            | <b>Latence &gt; 50ms</b>                   | CloudWatch + Azure Monitor corrélés |

## 4. CORRÉLATION MULTI-SOURCES NOC + SOC + CLOUD

### 4.1 Cas de Corrélation Réseau + Sécurité

La corrélation est la valeur ajoutée clé de la Phase 3. Elle permet de relier des événements qui, pris séparément, sembleraient sans rapport.

| Scénario                 | Signal Réseau (NOC)                                | Signal Sécurité (SOC)                              | Conclusion corrélée                          |
|--------------------------|----------------------------------------------------|----------------------------------------------------|----------------------------------------------|
| DDoS en cours            | Saturation subite bande passante WAN               | Pic d'alertes IPS, traffic flooding                | DDoS — activer mitigation, notifier client   |
| Machine compromise       | Trafic sortant anormal vers IP externe             | Malware signature détectée, connexions C2          | Hôte compromis — isoler, forensique          |
| Ransomware / chiffrement | Saturation I/O sur serveurs et NAS                 | Accès massifs fichiers + modification extensions   | Ransomware probable — isoler réseau          |
| Fuite de données         | Pic trafic sortant HTTP/HTTPS vers nouveau domaine | Données volumineuses transférées hors réseau       | Exfiltration — couper + alerter RSSI         |
| Attaque interne          | Scan ARP inhabituel sur réseau LAN                 | Utilisateur accède à des ressources hors périmètre | Menace interne — alerter RSSI + DRH          |
| Toll Fraud VoIP          | Saturation trunk SIP, appels internationaux        | Logs IPBX : appels depuis IP inconnue              | Fraude téléphonique — couper trunk + alerter |
| Shadow IT cloud          | Trafic vers régions cloud non autorisées           | API calls vers comptes cloud non inventoriés       | Shadow IT — cartographier + politique        |

### 4.2 Matrice de Corrélation — Qui Fait Quoi ?

| Type d'événement          | Détecté par                | Traité par               | Escalade à                      |
|---------------------------|----------------------------|--------------------------|---------------------------------|
| Panne réseau pure         | SolarWinds NPM             | N1 NOC (Runbook Phase 1) | N2 NOC                          |
| Dégradation applicative   | SolarWinds SAM + DPA       | N2 NOC + DBA             | N3 / Expert infra               |
| Incident sécurité pur     | SIEM Wazuh                 | Analyste SOC             | RSSI + N3                       |
| Corrélation réseau + sécu | SolarWinds + SIEM          | N2 NOC + Analyste SOC    | N3 + RSSI                       |
| Incident cloud            | CloudWatch / Azure Monitor | N2 NOC                   | N3 + équipe cloud               |
| DDoS / Flood              | NPM + IPS + SIEM           | Superviseur NOC + SOC    | Direction + Opérateur anti-DDoS |
| Ransomware / intrusion    | SIEM + EDR                 | SOC + RSSI               | Direction + CERT                |

## 5. RUNBOOKS INCIDENTS SÉCURITÉ

### 5.1 Principes Clés pour le NOC face à un Incident Sécurité

#### RÈGLE D'OR NOC vs INCIDENTS SÉCURITÉ

Le NOC N1 n'effectue JAMAIS d'analyse forensique. Son rôle est de DÉTECTER, QUALIFIER, CONTENIR et ESCALADER.

Contenir ≠ éteindre la machine. Une machine compromise éteinte peut détruire les preuves forensiques.

Toujours documenter les actions effectuées dans le ticket, avec horodatage précis.

La communication sur un incident sécurité est STRICTEMENT limitée aux personnes autorisées (pas de Slack public).

#### RB-07 : ALERTE SÉCURITÉ CRITIQUE — INTRUSION SUSPECTÉE

DÉCLENCHEUR : Alerte SIEM de sévérité CRITIQUE ou pattern d'attaque confirmé

##### ÉTAPE 1 — QUALIFICATION IMMÉDIATE (< 3 min)

- Alerte réelle ou faux positif ? Croiser avec d'autres sources (NPM, logs).
- Identifier la machine ou l'IP source et destination impliquée
- Identifier le client et l'impact potentiel

##### ÉTAPE 2 — ESCALADE IMMÉDIATE SOC / RSSI

- Escalade immédiate vers l'Analyste SOC ou le RSSI pour TOUT incident critique
- Ne PAS tenter de résoudre seul
- Ouvrir ticket P1 catégorie 'Incident Sécurité'
- Notifier le Superviseur NOC

##### ÉTAPE 3 — ACTIONS DE CONFINEMENT (sur instruction RSSI/SOC uniquement)

- Isoler la machine du réseau si instruction SOC (sans l'éteindre)
- Bloquer l'IP malveillante sur le firewall si instruction donnée
- NE PAS effacer les logs ni redémarrer la machine sans instruction

##### ÉTAPE 4 — DOCUMENTATION

- Chronologie précise de tous les événements dans le ticket
- Captures écran des alertes SIEM
- Préserver les logs pour analyse forensique

#### RB-08 : DÉTECTION DDOS / FLOOD RÉSEAU

DÉCLENCHEUR : Saturation subite BW WAN + alertes IPS + pic volumétrie trafic entrant

##### ÉTAPE 1 — CONFIRMATION (< 2 min)

- Saturation soudaine (DDoS) ou progressive (croissance trafic) ?
- Un seul client ou plusieurs clients (DDoS sur infrastructure partagée) ?
- L'accès au site visé est-il dégradé ou coupé ?

## ÉTAPE 2 — ESCALADE P1 IMMÉDIATE

- P1 immédiat — DDoS = incident majeur en télécoms
- Escalade Superviseur NOC + SOC + Direction
- Notifier le client immédiatement

## ÉTAPE 3 — ACTIONS TECHNIQUES

- Identifier les IP sources dans les logs IPS (top 10 IP sources)
- Blackhole routing ou RTBH si disponible sur le réseau de transit
- Activer le service anti-DDoS opérateur si contrat existant
- Rate limiting sur les accès si possible

## ÉTAPE 4 — COMMUNICATION

- Mise à jour client toutes les 15 min
- Rapport post-incident dans les 4h suivant la résolution



## 6. KPI SÉCURITÉ & CLOUD

### 6.1 KPI SOC

| KPI Sécurité                               | Cible    | Alerte      | Critique | Fréquence    |
|--------------------------------------------|----------|-------------|----------|--------------|
| MTTD — Mean Time To Detect (incident sécu) | < 10 min | < 30 min    | > 1h     | Par incident |
| MTTR — Incidents sécurité                  | < 4h     | < 8h        | > 24h    | Par incident |
| Taux vrais positifs SIEM                   | > 80%    | < 60%       | < 40%    | Hebdomadaire |
| Taux faux positifs SIEM                    | < 20%    | > 30%       | > 50%    | Hebdomadaire |
| Couverture logs (% sources actives)        | > 90%    | < 80%       | < 70%    | Mensuel      |
| Incidents sécurité P1 avec RCA             | 100%     | < 90%       | < 80%    | Mensuel      |
| Délai application correctif critique       | < 72h    | < 168h (7j) | > 30j    | Par CVE      |

### 6.2 KPI Cloud

| KPI Cloud                                      | Cible                | Alerte     | Critique    | Fréquence       |
|------------------------------------------------|----------------------|------------|-------------|-----------------|
| Disponibilité services cloud critiques         | > 99,9%              | < 99,5%    | < 99%       | Mensuel / hebdo |
| Latence connectivité cloud (Direct Connect/ER) | < 20ms               | > 40ms     | > 80ms      | Temps réel      |
| Dépassement budget cloud                       | < 110% budget        | 110-120%   | > 120%      | Quotidien       |
| Couverture supervision workloads cloud         | > 90%                | < 80%      | < 70%       | Mensuel         |
| Incidents cloud détectés proactivement         | > 70%                | < 50%      | < 30%       | Mensuel         |
| Drift de configuration cloud (IaC)             | 0 drift non planifié | > 3 drifts | > 10 drifts | Quotidien       |

## 7. AUTOMATISATIONS PRIORITAIRES PHASE 3

| #  | Automatisation                         | Description                                                                                                                       | Complexité | Gain                             |
|----|----------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|------------|----------------------------------|
| A1 | Blocage IP automatique                 | Si SIEM détecte brute force ou port scan depuis une IP → blocage automatique sur firewall via API, puis ticket + notification SOC | HAUTE      | Temps réaction : 0 min vs 15 min |
| A2 | Enrichissement alertes threat intel    | Chaque IP dans une alerte SIEM est automatiquement vérifiée dans AbuseIPDB/VirusTotal → score de réputation ajouté à l'alerte     | MOYENNE    | Triage 3x plus rapide            |
| A3 | Confinement automatique (hôte suspect) | Si SIEM détecte malware confirmé sur un hôte → isolation automatique du VLAN via switch API, notification SOC + client            | TRÈS HAUTE | Contention < 1 min vs 10-30 min  |
| A4 | Alerte budget cloud auto               | Si coût cloud dépasse 110% du budget mensuel → alerte automatique au client et à l'équipe FinOps                                  | FAIBLE     | 0 surprise facture cloud         |
| A5 | Rapport compliance automatique         | Génération mensuelle automatique des rapports de conformité SIEM (connexions admin, incidents, correctifs) pour chaque client     | MOYENNE    | Économie 1-2 jours/mois          |
| A6 | Corrélation DDoS → anti-DDoS           | Si NPM détecte saturation BW + SIEM détecte flood → activation automatique du mode scrubbing anti-DDoS opérateur                  | TRÈS HAUTE | Mitigation automatique < 2 min   |

## 8. DASHBOARDS SOC & CLOUD

| Dashboard                 | Audience            | Refresh    | Contenu                                                                                                 |
|---------------------------|---------------------|------------|---------------------------------------------------------------------------------------------------------|
| SOC — Wall Board Sécurité | Analyste SOC + RSSI | Temps réel | Alertes SIEM actives, TOP 10 IP suspectes, incidents ouverts, hôtes compromis, géolocalisation attaques |
| Threat Intelligence Board | RSSI + N3           | 15 min     | IPs blacklistées actives, IOCs détectés, CVEs applicables, tendances attaques du mois                   |
| Cloud Health Dashboard    | N2 + Cloud Team     | 5 min      | Disponibilité services cloud par provider, latence Direct Connect, coûts vs budget, alertes actives     |
| Corrélation NOC+SOC       | Superviseur + SOC   | Temps réel | Événements corrélés réseau+sécurité, score de risque par client, incidents multidimensionnels           |
| Compliance & Audit        | RSSI + Direction    | Mensuel    | Connexions admin, changements de config, incidents sécurité, taux conformité, correctifs appliqués      |

### 8.1 Plan de Déploiement Phase 3

| Mois | Action                                                 | Prérequis                                                        | Résultat                                                  | Complexité |
|------|--------------------------------------------------------|------------------------------------------------------------------|-----------------------------------------------------------|------------|
| M9   | Déployer Wazuh Manager et agents serveurs prioritaires | Serveurs Phase 2 opérationnels Accès SSH/WMI                     | SIEM opérationnel<br>Premières alertes actives            | HAUTE      |
| M10  | Intégrer logs firewalls et équipements réseau          | Syslog activé sur tous équipements Port UDP 514 ouvert vers SIEM | Logs réseau centralisés<br>Corrélation réseau+sécu active | MOYENNE    |
| M10  | Déployer monitoring cloud (AWS + Azure en priorité)    | Accès lecture CloudTrail / Activity Logs Credentials API cloud   | Workloads cloud supervisés<br>Alertes coûts actives       | MOYENNE    |
| M11  | Activer threat intelligence (AbuseIPDB / VirusTotal)   | API keys TI Accès SIEM configuré                                 | Enrichissement automatique des alertes SIEM               | MOYENNE    |
| M12  | Automatisation blocage IP (SIEM → Firewall API)        | API Firewall disponible<br>Playbook validé RSSI                  | Blocage automatique en < 1 min                            | HAUTE      |
| M13  | Déployer Grafana dashboards unifiés                    | Sources: SolarWinds + Wazuh + Cloud                              | Vue unifiée NOC+SOC+Cloud sur un seul écran               | MOYENNE    |
| M14  | Rapport compliance automatisé                          | Données SIEM 3 mois minimum                                      | Rapport mensuel automatique pour chaque client            | FAIBLE     |

#### RÉSUMÉ PHASE 3 — CE QUE VOUS GAGNEZ

À l'issue de la Phase 3 (M8-M14), le NOC+SOC sera capable de :

- Détecter les incidents sécurité en moins de 10 minutes (vs aucune détection aujourd'hui)
- Corréler automatiquement les événements réseau, sécurité et cloud
- Superviser les workloads AWS, Azure et GCP avec les mêmes standards que l'on-premise
- Bloquer automatiquement les IP malveillantes détectées par le SIEM

- Produire des rapports de conformité automatiques pour chaque client
- Proposer une offre SOC-as-a-Service à vos clients High Value (upsell stratégique)